

Insider Credential Theft and Misuse response

Insider Threat · **Critical** severity · SOC IR Playbook

Incident type	Insider Threat - Credential Abuse
Severity	Critical
Priority	Critical
Detection sources	SIEM, UEBA (User and Entity Behaviour Analytics), IAM, EDR, DLP, HR tips or whistleblower reports

Scenario

An insider (or an external actor using stolen insider credentials) uses valid accounts to access sensitive systems, extract data or perform unauthorised activities - often bypassing traditional security detection due to use of legitimate credentials.

MITRE ATT&CK

T1078, T1087, T1110.003, T1213.003

Preparation

Implement UEBA solutions Detect anomalous user activity (e.g., Exabeam, Microsoft Defender, Securonix) Enable logging for privileged accounts Include session monitoring and command tracking Enforce least privilege & RBAC Ensure users only have access they truly need Monitor for sensitive data access DLP policies for file downloads, cloud storage, email forwarding Set up alerting on atypical access patterns Time of day, volume of activity, system accessed, location

Detection & Analysis

Alert from UEBA or SIEM Abnormal data access, login behaviour or file movement Correlate with job role Determine if actions align with user's normal duties Check access logs Identify systems, files and data accessed Review recent HR flags Check if the user is under investigation, has resigned or shows behavioural risk indicators

Containment

Suspend user account Temporarily disable access during investigation Revoke session tokens Invalidate active sessions, VPN or API tokens Quarantine endpoint If file transfer, malware installation or persistence is suspected Restrict further access Implement just-in-time access or isolate the user's VLAN/subnet

Eradication

Investigate full activity scope Review emails sent, files accessed/transferred, systems logged into Revoke elevated access or credentials Remove access from all privileged systems or services Reset credentials and keys For shared credentials or systems the user accessed Clean up any changes Roll back any script, configuration or data changes made by the user

Recovery

Restore access to legitimate users If other accounts were suspended or disabled for investigation Monitor systems touched Use SIEM and EDR to monitor post-incident behaviour for a defined period Notify stakeholders Include HR, Legal and Compliance for coordination and investigation closure Resume normal operations Once it is verified that no lingering risk remains from insider activity

Lessons Learned & Reporting

Conduct a post-incident review Determine how the misuse occurred and what failed to detect it earlier Update detection rules Add specific indicators of abuse for similar roles or behaviour Review access policies Tighten or adjust RBAC/least privilege settings and IAM processes Enhance user monitoring policies Periodic review of sensitive access by job role or department Report if required Internal governance bodies, regulators (e.g., PDPA,

HIPAA) or affected clients

Tools typically involved

SIEM (e.g., Splunk, Sentinel, QRadar); UEBA (e.g., Exabeam, Microsoft Defender for Identity, Securonix); EDR (e.g., CrowdStrike, Cortex XDR); IAM/SSO logs (e.g., Okta, Azure AD, Ping); DLP tools (e.g., Forcepoint, Symantec, Microsoft Purview); Endpoint and server logs; HRIS integration (for real-time HR status feed)

Success metrics (SLA targets)

Detection Time <15 minutes from abnormal activity onset Account Suspension Time <30 minutes from alert confirmation Root Cause Analysis Completion Within 48 hours Access Review Completion 100% of privileged access logs reviewed for the impacted user Policy Review or Adjustment Within 7 days of incident closure